

**Kontinuasjonseksamen
CYB 2100 – Cyberforsvar
Høgskolen Kristiania
Februar 2025**

Eksamen: Individuell hjemmeksamen

Varighet: 7 dager

Gradering: Nasjonal karakterskala A – F (F er ikke bestått)

Vekting: 100% av vurderingen

Hjelpemidler: Alle

Akademisk kontakt: Henrik Ramberg, henrik.ramberg@kristiania.no

Besvarelse: Oppgaven skal leveres som en PDF-fil med skriftstørrelse 12 og 1,5 linjeavstand. Fonten skal være av typen «Times New Roman» eller «Arial», med svart farge på hvit bakgrunn. Alle marger skal være standard 2,5 cm. Besvarelsen har en maksimal begrensning på 10 sider inkludert figurer og tabeller. Referanselisten kommer i tillegg. Vær klar og tydelig i din besvarelse. Husk å oppgi kandidatnummer på din besvarelse, ikke studentnummer.

Plagiatkontroll: Det forventes at studenten egenhendig produserer sin egen besvarelse. Vær nøye med bruk av kildereferering. Det er krav til APA7 referansestil, svak eller manglende referanseføring gir vesentlig trekk i resultatet. Det gjennomføres plagiatkontroll på alle innleveringer, bacheloroppgaver og masteroppgaver. Se forøvrig retningslinjene for kildehenvisning, plagiat og formelle krav til innlevering.

Les igjennom hele oppgaven før du begynner på besvarelsen. Lykke til!

Oppgave 1 (30% vektning)

1.a 'Business Continuity' og 'Disaster Recovery' er viktige konsepter i cyberforsvar. Forklar forskjellen mellom 'Business Continuity' og 'Disaster Recovery', og hovedelementene i hver av dem. For å begrense omfanget av oppgaven tar du for deg de 3 hovedelementene du mener er viktigst.

1.b På ordinær eksamen i november 2024 så vi på en programvare vi antok at kunne være skadevare. Vi skal nok en gang ta utgangspunkt i den samme programvaren i denne oppgaven. Nå legger vi til grunn at det er skadevare og at den er polymorf. Selv om programvaren er polymorf, kan du anta at 16 bytes på offset 0 er statisk. Det samme gjelder 32 bytes på offset 256 og 16 bytes på offset 1024.

Med dette som utgangspunkt skal du lage en Yara-regel som detekterer skadevaren. Oppgaven skal løses på Cybuntu i en mappe du kaller "kandidatnr-1b", hvor 'kandidatnr' er ditt kandidatnummer. Er for eksempel ditt kandidatnummer 1313 blir altså mappenavnet 1313-1b. Du må vise at din Yara-regel virker, og du må dokumentere grundig med tekst og bilder. Yara-regelen skal selvsagt være inkludert i besvarelsen.

Under finner du en lenke til filen (Passord: EksamenNov24):

<https://drive.google.com/file/d/1hPjVuG-Omlavdt87YWgbNVPvR0aLJpii/view?usp=sharing>

1.c Du skal nå lage en ClamAV signatur for den samme filen som i oppgave 1.b. Du skal fortsatt anta at skadevaren er polymorf, og at de samme områdene i filen er statiske. Oppgaven skal løses på Cybuntu i en mappe du kaller "kandidatnr-1c" hvor kandidatnr er ditt kandidatnummer. Det er viktig at du viser at din signatur detekterer skadevaren og at du dokumenterer grundig med bilder og tekst. Signaturen skal selvsagt være inkludert i besvarelsen.

Oppgave 2 (30% vektning)

2.a Wazuh er en gratis og «open source» SIEM og EDR platform. Gjør rede for fordeler og ulemper ved å bruke åpen kildekode-produkter i sikkerhetssammenheng. Hvilke organisasjoner mener du er best egnet til å bruke Wazuh? Argumenter for svaret ditt.

2.b I denne oppgaven skal vi ta utgangspunkt i et datasettet du finner her (md5sum: 6ea8f15cc4ccf6186db7a31415c09c58):

https://s3.amazonaws.com/botsdataset/botsv2/botsv2_data_set_attack_only.tgz

Demonstrer at du klarer å laste inn datasettet, og eventuelt laste ut andre datasett du har i Splunk fra før. Det er viktig at du laster ut eventuelt andre datasett da dette kan påvirke svarene i neste oppgave. Denne oppgaven skal løses på VMen vi har brukt i faget, og det er viktig at dette fremkommer av skjermbildene i besvarelsen din. Når du har riktig datasett kjører du følgende kommando for å vise at du har lastet riktig datasett:

```
" | eventcount summarize=false index=* | dedup index | fields index"
```

Det er viktig at du dokumenterer fremgangsmåte og resultat ved hjelp av bilder og tekst.

2.c Med utgangspunkt i datasettet nevnt i 2.b skal du svare på følgende spørsmål;

- Hvor mange unike e-poster klarer du å finne i datasettet?
- Lag en spørring som lister de 3 e-postene med høyest frekvens.
- Hvor mange exe filer blir overført via tcp i datasettet? List ut navnene på disse exe filene, om nødvendig kan du sette en begrensning på 10 i visningen.
- Hvor mange FTP forbindelser blir opprettet for å laste opp data i datasettet?
- Hvilke(t) passord ser ut til å være delt blant brukere som logger på <http://store.froth.ly>?

Kjør spørringer mot datasettet for å finne svar på spørsmålene over. Forklar hvordan du går frem og hvilke spørringer du kjørte. Det er viktig at du dokumenterer med skjermbilder. Legg også ved SPLene dine inn i teksten som del av svaret. Oppgaven skal løses på VMen vi brukte i faget.

Oppgave 3 (40% vektning)

3.a Denne oppgaven teller halvparten av oppgave 3, det er derfor viktig at du prioriterer et fylldig svar på denne.

Ta for deg rapporten «Risiko 2025» utgitt av norske myndigheter 5.februar i år. Du skal sammenligne denne rapporten med «Risiko 2024» og «Risiko 2023», og gjøre rede for endringene i trusselbildet vi står ovenfor i Norge. For å begrense denne delen av oppgaven skal du ta for deg det du mener er de tre største endringene i årets rapport. Det er viktig at du beskriver det du mener er de største truslene og argumenterer for ditt syn.

Når du har gjort rede for truslene skal du som CISO for et middelsstort selskap i Norge forklare hvordan du kan mittigere for truslene ved å bruke NSMs grunnprinsipper for IKT-sikkerhet 2.1. Du skal begrense denne delen av oppgaven til tre prinsipper som du mener ville gitt størst effekt for å mitigere de identifiserte truslene.

Det er et krav at du minst refererer til «Risiko 2025», «Risiko 2024», «Risiko 2023» samt NSMs Grunnprinsipper for IKT-sikkerhet 2.1.

3.b Forklar en typisk incident response prosess med utgangspunkt i lærebøkene og forelesningene. Hva er de viktige stegene i en slik prosess og hva er sammenhengen mellom stegene?

3.c Tenk deg at du jobber som hendelseshåndterer i et stort norsk selskap. Du får en henvendelse fra en ansatt som er engstelig for at vedkommende er infisert med skadevare etter å ha åpnet en epost. Som hendelseshåndterer er det din oppgave å komme til bunns i saken. Du har bedt vedkommende om en kopi av den mistenkelige eposten og har fått oversendt filen i lenken under. Filen er passordbeskyttet (passord: Konte2025)

https://drive.google.com/file/d/1rW_am2NIZqGo3jXhxyjpGuVq2Il68rYA/view?usp=sharing

Hva har den ansatte mottatt? Er det noe skadevare i eposten? Forklar hvordan du går frem for å analysere epost og innhold. Dokumenter hvordan du kommer frem til svaret og dokumenter nøye med bilder. Det anbefales at denne oppgaven løses på annet operativsystem enn Windows.

Slutt på oppgavesettet.